A Byzantine-Robust Secure Federated Learning Scheme in Heterogeneous Data

Jinbo Wang, Ruijin Wang, Zengpeng Li, Fengli Zhang, Jingwei Li, *Member, IEEE*, and Xiong Li, *Senior Member, IEEE*

***Abstract*—Secure Federated Learning protects user privacy by keeping local gradients within the ciphertext space, thereby preventing direct exposure of raw gradients during aggregation. Paradoxically, this very protection introduces a fundamental vulnerability: the opacity of encrypted gradients blinds the server, rendering honest and malicious gradients indistinguishable. An attacker can exploit this opacity to inject manipulated gradients directly into the secure aggregation process, compromising the integrity of the global model. To address this issue, we propose SFLBR, a novel Byzantine-robust Secure Federated Learning framework. Specifically, we adopt the gradient median as a robust benchmark and introduce a layer-wise cosine similarity metric to differentiate malicious gradients. Furthermore, considering the complexity of non-independent and identically distributed (Non-IID) scenarios, we further design a proactive defense strategy that constrains the divergence among honest gradients, and augment it with a trust score function to improve robustness against potential misjudgments. Finally, we construct a series of secure communication protocols based on a lightweight dual-masking encryption mechanism, which enable efficient robust aggregation directly within the ciphertext space. Extensive experiments validate the effectiveness of SFLBR, demonstrating state-of-the-art (SOTA) defense performance across diverse attack scenarios.**

***Index Terms*—Federated learning, Byzantine attacks and defenses, privacy preservation, heterogeneous data.**

I. Introduction

FEDERATED Learning (FL) [1] is a rapidly evolving distributed learning paradigm that enables collaborative training of neural network models. It operates by transmitting users' local gradients, rather than their raw data, to a parameter server for aggregation. This privacy preservation property has established FL as a foundational technique across domains with stringent data confidentiality requirements, such as medical diagnosis [2] and autonomous driving [3].

Despite the considerable potential of FL, recent studies have revealed substantial privacy risks associated with the exchange of raw gradients between users and the parameter server. An adversarial server can not only infer the distribution of the training data, but also reconstruct the original training samples from local gradients [4], [5]. In light of these concerns, Secure Federated Learning (SFL) [6], [7], [8], [9], [10], [11] has emerged as a promising paradigm to address privacy vulnerabilities. In SFL, users encrypt their local gradients before transmission, thereby ensuring that these gradients are processed within a ciphertext space that is inaccessible to external adversaries. Currently, the primary cryptographic techniques employed for privacy preservation in FL include homomorphic encryption (HE) [9], [10], secure multi-party computation (SMC) [6], [7], and differential privacy (DP) [8], [12].

Byzantine attacks [13], [14], [15], [16] pose another critical security threat in FL, wherein malicious users transmit malicious gradients to undermine the integrity of the global model. These attacks can be broadly categorized into two types: untargeted attacks, which aim to degrade model utility [13], and targeted (or backdoor) attacks, which seek to induce misclassification on specific sub-tasks while preserving accuracy on main-task [14]. Various defenses against Byzantine attacks have been proposed. One line of research focuses on robust aggregation algorithms that reduce the influence of malicious gradients during global aggregation [17], [18]. However, these methods often sacrifice convergence efficiency, resulting in slower model training. Another line of defense employs similarity metrics, such as cosine similarity [19] or Euclidean distance [20], to distinguish honest gradients from malicious ones.

While privacy preservation and Byzantine robustness can each be addressed individually with well-established techniques, jointly achieving them introduces a fundamental tension in FL. Cryptographic techniques such as HE [11] and SMC [20] effectively protect gradient privacy, yet they remain inherently incompatible with existing Byzantine defenses: the opacity of encrypted gradients blinds the server, rendering honest and malicious gradients indistinguishable, thereby neutralizing existing defense mechanisms (e.g., those based on

Received 27 February 2025; revised 27 February 2026 and 18 May 2026; accepted 8 July 2026. Date of publication 16 July 2026; date of current version 11 August 2026. This work was supported in part by the National Natural Science Foundation of China under Grant U2333207, Grant 62271128, Grant U25A20429, and Grant 62332018; in part by the Key Research and Development Projects of Sichuan Provincial Science and Technology Plan under Grant 2022ZDZX0004 and Grant 2025ZHRG0006; in part by Sichuan Major Science and Technology Projects under Grant 2025ZDZX0093; in part by Sichuan Science and Technology Program "Revitalization by Challenge" Projects under Grant 2023YFG0374; in part by Sichuan Regional Innovation Cooperation Projects under Grant 2025YFHZ0302; and in part by Chengdu Key Research and Development Support Program Projects under Grant 2025-YF12-00029-RC, Grant 2025-YF08-00128-GX, and Grant 2026-YF11-00032-HZ. The associate editor coordinating the review of this article and approving it for publication was Prof. Hessam Mahdavifar. *(Corresponding author: Ruijin Wang.)*

Jinbo Wang, Ruijin Wang, and Fengli Zhang are with the School of Information and Software Engineering, University of Electronic Science and Technology of China, Chengdu 610054, China (e-mail: 202411090904@std.uestc.edu.cn; ruijinwang@uestc.edu.cn; fzhang@uestc.edu.cn).

Zengpeng Li is with the School of Cyberspace Security, Shandong University, Jinan, Shandong 250100, China (e-mail: lizengpeng@sdu.edu.cn).

Jingwei Li and Xiong Li are with the School of Computer Science and Engineering, University of Electronic Science and Technology of China, Chengdu 610097, China (e-mail: jwli@uestc.edu.cn; lixiong@uestc.edu.cn).

This article has supplementary downloadable material available at https://doi.org/10.1109/TIFS.2026.3714122, provided by the authors.

Digital Object Identifier 10.1109/TIFS.2026.3714122

1556-6021 © 2026 IEEE. All rights reserved, including rights for text and data mining, and training of artificial intelligence and similar technologies. Personal use is permitted, but republication/redistribution requires IEEE permission.
See https://www.ieee.org/publications/rights/index.html for more information.

Authorized licensed use limited to: Anhui University. Downloaded on October 10,2026 at 11:47:06 UTC from IEEE Xplore. Restrictions apply.

cosine similarity or Euclidean distance). DP [8], [12] offers privacy through noise perturbation, but its protective efficacy hinges on a delicate trade-off: excessive noise degrades model utility, whereas insufficient noise fails to provide meaningful privacy guarantees. This tension highlights the critical need for a unified framework that simultaneously addresses both privacy and Byzantine threats in FL.

To address this issue, we identify two major challenges. *1) Distinguishing between honest and malicious gradients within the ciphertext space is inherently difficult.* In the physical world, objects inside a black box can often be identified through indirect attributes such as weight or size without revealing their contents. In the digital domain, however, encrypted gradients eliminate such possibilities: the privacy and randomness of the secret key prevent any direct verification of gradient authenticity. As a result, reliably distinguishing honest from malicious gradients within the ciphertext space becomes extremely challenging. *2) The confusion between honest and malicious gradients is further intensified when users' data is Non-IID [21], [22].* When the data across users is IID, gradients tend to follow similar distributions and directions, making it easier to identify malicious gradients that deviate in direction. Under Non-IID conditions, however, gradients no longer conform to a shared pattern, and their directions diverge more widely. Consequently, distinguishing malicious gradients becomes substantially more difficult, as statistical deviations can be easily conflated with the inherent heterogeneity of honest gradients in Non-IID scenarios.

To tackle these challenges, this paper proposes a novel Byzantine-robust Secure Federated Learning scheme, termed SFLBR, which effectively combats Byzantine attacks while employing lightweight encryption for privacy preservation. Specifically, inspired by statistical analysis [17], we observe that when the proportion of malicious gradients remains below 50%, the coordinate-wise median of the gradients consistently aligns with the honest gradients, thereby providing a reliable benchmark for identifying anomalous gradients. Furthermore, we argue that the difficulty of distinguishing malicious gradients in Non-IID scenarios stems from the proactive nature of attacks and the reactive nature of defenses. Motivated by this insight, we design a novel proactive defense strategy in which identifiable signals are injected into honest gradients prior to attacks, facilitating subsequent identification of malicious gradients. In addition, to mitigate the risk of misidentifying honest gradients as malicious, we introduce a trust score function to enhance the robustness of SFLBR against such misjudgments. Finally, we construct a series of secure communication protocols based on a dual-masking encryption mechanism to enable the efficient execution of SFLBR within the ciphertext space.

The main contributions of this paper are summarized as follows:

- Inspired by proactive defense, we introduce a penalty term based on the L2 distance of the difference between each user's local model and the global model, which proactively constrains the local model from drifting excessively. This regularization term enhances the distinguishability between malicious and honest gradients, particularly in Non-IID scenarios.
- We develop a Byzantine-robust aggregation algorithm that adopts the gradient median as a benchmark, computes layer-wise cosine similarity between the encrypted gradients and the benchmark, and uses a trust score function to assign aggregation weights based on this similarity.
- We propose a lightweight privacy preservation scheme built upon a dual-masking encryption mechanism, comprising *LocalTrain*, *SecureMedian*, *SecureTrustScore*, and *SecureAggregation*. These protocols enable the efficient execution of SFLBR within the ciphertext space.
- We provide theoretical analyses of the security, convergence, and complexity of SFLBR. Moreover, extensive experiments demonstrate that SFLBR achieves SOTA defense performance across diverse attack scenarios.

II. Related Work

A. Secure Federated Learning

Although FL aggregates knowledge by sharing gradients rather than raw user data, recent studies reveal that gradients can still leak sensitive user information [4], [5]. This underscores the imperative to protect gradients from privacy leakage. Commonly adopted cryptographic techniques in FL include HE [9], [10], SMC [6], [7], and DP [8], [12]. Specifically, additive HE has been employed to ensure gradient privacy during aggregation [9], [10]. Bonawitz et al. [6] proposed secure aggregation, which encrypts gradients using secret sharing and a pseudo-random generator. Xu et al. [7] extended this protocol with integrity verification, and Wu et al. [8] combined adaptive gradient descent with DP to mitigate overfitting while strengthening gradient privacy.

While the above cryptographic techniques effectively protect gradient privacy, they remain inherently vulnerable to Byzantine threats posed by malicious users.

B. Byzantine-Robust Aggregation Algorithm

Byzantine attacks [13], [14], [15], [16] compromise global model integrity by injecting malicious gradients into the aggregation process. Several defenses seek to reduce the influence of these malicious gradients on the global model. For example, Median [17] takes the coordinate-wise median of users' local gradients as the global gradient. Trimmed Mean [17] discards the largest and smallest gradient values per coordinate and then computes the average of the remaining values. Krum [18] selects the local gradient with the smallest sum of pairwise L2 distances to the other gradients as the global gradient. However, these approaches discard a substantial fraction of honest gradients, which slows the convergence of the global model. In contrast, FLTrust [19] computes cosine similarities between local gradients and a "trust root" derived from a clean dataset, and uses these similarities directly as aggregation weights. Auror [23] employs k-means clustering to identify anomalous gradients that deviate from the majority. FedREDefense [24] posits that honest gradients contain richer effective knowledge, and detects malicious gradients by distilling local knowledge

Authorized licensed use limited to: Anhui University. Downloaded on October 10,2026 at 11:47:06 UTC from IEEE Xplore. Restrictions apply.

TABLE I
COMPARISON BETWEEN SFLBR AND PREVIOUS SCHEMES

Solution	Data Scenarios	Data Privacy	Byzantine Robustness	Defense Strategy	Privacy Guarantee	Server
FedAvg [1]	IID	-	○	-	○	Single
Krum [18]	IID	-	●	L2 norm	○	Single
Median [17]	IID	-	●	Median	○	Single
T-mean [17]	IID	-	●	Trimmed	○	Single
SA [6]	IID	SMC	○	-	●	Single
FLOD [25]	IID	HE	●	Clean data	●	Dual
ShieldFL [10]	IID	HE	●	Cosine	●	Dual
PEFL [9]	IID	HE	●	Pearson	●	Dual
Solution [11]	All	HE	●	Mahalanobis	●	Dual
LSFL [20]	IID	2PC	●	L2 norm	●	Dual
RFLPA [26]	IID	SMC	●	Cosine	●	Single
DP-BREM [12]	IID	DP	●	Momentum	●	Single
SFLBR	All	Mask	●	Cosine & Proactive	●	Dual

* ○ indicates the problem is not resolved, ● indicates the problem is resolved.

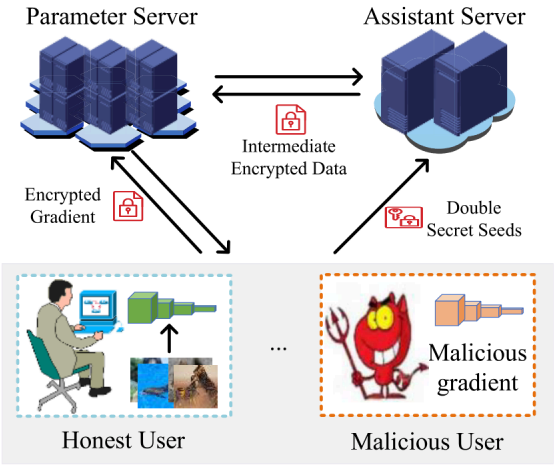


Fig. 1. System model.

and measuring the reconstruction error. Yet, these Byzantine-robust algorithms focus primarily on defending against attacks, leaving the inherent privacy risks largely unaddressed.

To simultaneously achieve both privacy preservation and Byzantine robustness, several recent works have integrated cryptographic techniques into Byzantine-robust FL. Dong et al. [25] proposed FLOD, an enhanced version of FLTrust that leverages HE as the underlying encryption primitive to protect gradient privacy. Similarly, PEFL [9] employs additive HE and a dual-server architecture to collaboratively ensure gradient privacy while preserving Byzantine robustness. Yazdinejad et al. [11] also adopt additive HE for privacy, combining an internal auditor with the Mahalanobis distance to achieve Byzantine-robust aggregation. ShieldFL [10] achieves the same objective through two-trapdoor HE with a dual-server design. All of these schemes rely on HE as the core encryption technology, which imposes considerable computational overhead on the FL system. DP-BREM [12] instead employs DP to safeguard user privacy and introduces local gradient momentum to accelerate convergence while enhancing Byzantine robustness. However, DP inevitably degrades global model performance, introducing an intrinsic trade-off between privacy and utility. In contrast, SMC is computationally lightweight and does not impair model performance. LSFL [20] protects user privacy via additive secret sharing and uses the coordinate-wise median of gradients as a benchmark, calculating L2 distances of local gradients to identify malicious ones. RFLPA [26] distributes gradient secret sharing, cosine distance computation, and robust aggregation to the user side, while the server performs normalization verification, cosine distance recovery, and aggregation reconstruction. Unfortunately, these existing approaches do not adequately account for the Non-IID scenarios that commonly arise in practical FL. The inherent heterogeneity of users' local data causes substantial divergence among their gradients, which in turn renders existing malicious gradient differentiation schemes ineffective.

To address the above challenges, we propose SFLBR. It protects user privacy through an efficiently dual-masking encryption mechanism, achieves Byzantine robustness using a gradient median benchmark, and introduces a proactive defense strategy to enhance the robustness of SFLBR under Non-IID scenarios. A detailed comparison of the SFLBR with existing schemes is described in TABLE I.

III. PROBLEM STATEMENT

A. System Model

The research objective of this paper is to simultaneously achieve privacy preservation and Byzantine robustness in FL. Specifically, privacy preservation aims to keep user gradients invisible to the server, whereas Byzantine robustness requires the server to have white-box access to gradients in order to detect malicious ones. This inherent contradiction renders traditional single-server FL frameworks incapable of satisfying both security requirements at the same time. Moreover, Non-IID scenarios amplify the divergence among honest gradients, further complicating the detection of malicious gradients within the ciphertext space. Although DP protects privacy by injecting noise rather than confining gradients to the ciphertext, the added noise inevitably degrades model performance [12].

To achieve this objective without compromising model performance, existing approaches adopt HE in conjunction with a dual-server architecture [9], [10], [11], [20], [25]. These works design a suite of secure communication protocols between the two servers to jointly ensure Byzantine robustness and gradient privacy. Given the challenges inherent in this objective and the prevalence of the dual-server paradigm, we likewise adopt a dual-server architecture and design a series of secure communication protocols built upon a lightweight dual-masking encryption mechanism. This design attains the research objective while ensuring that the computational and communication overhead of the two servers remains substantially lower than that of existing HE-based schemes. Our system model is illustrated in Fig. 1.

The following is a description of the basic entities that exist in the system model.

- *Users:* All users compute local gradients based on the global model and their local data. To preserve privacy, users employ a dual-masking encryption mechanism to generate encrypted gradients using dual secret seeds, thereby preventing unauthorized external access.

Authorized licensed use limited to: Anhui University. Downloaded on October 10,2026 at 11:47:06 UTC from IEEE Xplore. Restrictions apply.

- *Parameter Server (PS):* The PS receives and aggregates the encrypted gradients from users and updates the global model. It collaborates with the AS to securely compute the gradient median, trust scores, and global gradient.
- *Assistant Server (AS):* The AS holds the dual secret seeds of all users and assists the PS in conducting the necessary computations while preserving user privacy.

B. Threat Model

This paper mainly considers two security threats in FL systems: Byzantine threat and privacy threat.

For the Byzantine threat, we assume that the set of participating FL users contains a subset of malicious users. These malicious users possess partial knowledge of the FL system, including their own local data and the global model parameters distributed by the server. They launch Byzantine attacks by manipulating training data, code, or directly tampering with local gradients, with the aim of compromising the integrity of the global model. We further consider a stronger threat model in which malicious users are aware of the total number of participants and even the honest gradients, thereby enabling more powerful Byzantine attacks [15], [16]. To better reflect real-world conditions and maintain consistency with prior work [9], [10], [11], [20], [26], we assume that the proportion of malicious users remains strictly below 50%.

For the privacy threat, we assume that the dual servers are honest-but-curious, meaning they faithfully follow the prescribed protocols but may attempt to infer user privacy from the information available to them. Crucially, we assume that the two servers, though honest-but-curious, do not collude; otherwise, they would essentially reduce to a single server. This non-collusion assumption is both reasonable and practically enforceable for the following reasons. First, non-colluding dual servers have been widely adopted in the literatures [9], [10], [11], [20], and [25], where [11] even assumes a fully trusted third party. Second, in real-world deployments, non-collusion can be effectively realized by placing the two servers under independent organizations with divergent or even competing interests, or by hosting one server within a trusted execution environment such as Intel SGX [27]. The dual-server architecture thus distributes the trust assumption from a single completely trusted entity to two non-colluding, honest-but-curious entities. In practice, identifying a single entity that all participants unconditionally trust is extremely difficult; conversely, finding two entities with conflicting interests—rendering collusion rather unlikely—is far more feasible.

IV. Proposed Scheme

A. Motivation

Existing dual-server frameworks struggle to achieve satisfactory Byzantine robustness and privacy preservation, primarily owing to two fundamental challenges: *1)* distinguishing malicious gradients within the ciphertext space is inherently difficult. *2)* Non-IID scenarios further blur the distinction between honest and malicious gradients. To address these challenges, an intuitive idea is to establish a benchmark that can reliably separate honest gradients from malicious ones.

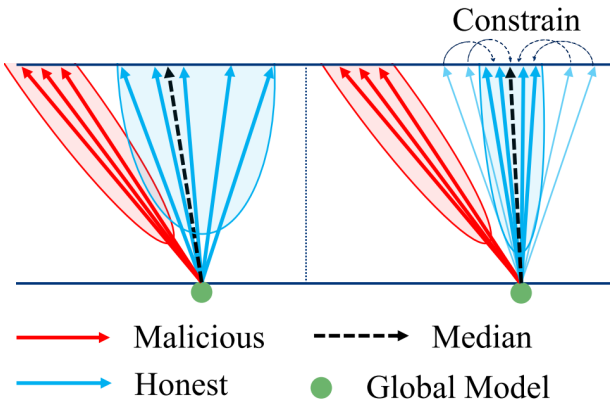


Fig. 2. Motivation of gradient median and proactive defense.

Motivation 1. FLTrust [19] assumes that the server holds a clean dataset locally to train a virtual global model, which then serves as the trust benchmark. However, this assumption is often unrealistic in practice. An alternative is to use the global gradient from the previous round as the benchmark, but after model convergence the global gradient tends to oscillate, severely impairing its discriminative power. Statistical analysis [17] has shown that the gradient median can reliably separate honest gradients from malicious ones when the proportion of malicious users remains below 50%. Theoretically, when malicious gradients deviate from the distribution of honest gradients, the gradient median consistently aligns with the honest gradients, as illustrated on the left side of Fig. 2.

Motivation 2. Non-IID scenarios cause honest gradients to diverge, further complicating the distinction between honest and malicious gradients. We attribute this difficulty to the proactive nature of Byzantine attacks and the inherently reactive nature of existing defenses. Motivated by this insight, we argue that deploying proactive defenses before attacks take place is considerably more effective than adopting reactive countermeasures afterward. Concretely, identifiable signals can be proactively embedded into honest gradients before they are exposed to malicious influence, thereby enhancing the detectability of honest gradients. This idea is illustrated on the right side of Fig. 2.

B. Workflow

Building on **Motivation 1** and **Motivation 2**, we propose SFLBR, a novel Byzantine-robust secure federated learning framework. Unlike prior frameworks [9], [10], [17], [18], [19], [25] that are primarily tailored to IID scenarios, SFLBR integrates a proactive defense strategy with the gradient median as a benchmark, enabling robust operation in Non-IID scenarios.

The workflow of SFLBR is summarized in Algorithm 1 and consists of four core secure communication protocols: *LocalTrain*, *SecureMedian*, *SecureTrustScore*, and *SecureAggregation*. First, users leverage the global model distributed by the PS together with their local data to execute the *LocalTrain* protocol, producing encrypted gradients. Second, the PS and

Authorized licensed use limited to: Anhui University. Downloaded on October 10,2026 at 11:47:06 UTC from IEEE Xplore. Restrictions apply.

Algorithm 1 SFLBR Scheme

Input: Number of users N, global communication rounds T, global learning rate η.
Output: The global model $\boldsymbol{w}^{\boldsymbol{T}}$ of T-th round.
PS initialize the global model $\boldsymbol{w}^{\boldsymbol{0}}$.
for t in $[0, T]$ **do**
  /*User encrypts local gradient, note that $[x]$ is Encrypted x.*/
  for i in $[1, N]$ parallel **do**
    User i receives $\boldsymbol{w}^{\boldsymbol{t}}$ from PS.
    $[\boldsymbol{g}_i^{\boldsymbol{t+1}}] \leftarrow$ *LocalTrain*(i,t,$\boldsymbol{w}^{\boldsymbol{t}}$).
    Sends $[\boldsymbol{g}_i^{\boldsymbol{t+1}}]$ to PS, double secret keys to AS.
  end for
  /*PS and AS compute gradient median from all encrypted gradients.*/
  $[\boldsymbol{g}_{\boldsymbol{med}}^{\boldsymbol{t+1}}] \leftarrow$ *SecureMedian*($[\boldsymbol{g}_1^{\boldsymbol{t+1}}]$,$[\boldsymbol{g}_2^{\boldsymbol{t+1}}]$,...,$[\boldsymbol{g}_N^{\boldsymbol{t+1}}]$).
  /*PS and AS compute trust scores based on layer-wise cosine similarity.*/
  for i in $[1, N]$ **do**
    $\mu_i \leftarrow$ *SecureTrustScore*($[\boldsymbol{g}_i^{\boldsymbol{t+1}}]$,$[\boldsymbol{g}_{\boldsymbol{med}}^{\boldsymbol{t+1}}]$).
  end for
  for i in $[1, N]$ **do**
    $\rho_i = \frac{\mu_i}{\sum_{i=1}^{N} \mu_i}$.
  end for
  /*PS and AS execute Byzantine-robust aggregation.*/
  $\boldsymbol{g}^{\boldsymbol{t+1}} \leftarrow$ *SecureAggregation*(ρ_1,..,ρ_N;$[\boldsymbol{g}_1^{\boldsymbol{t+1}}]$,..,$[\boldsymbol{g}_N^{\boldsymbol{t+1}}]$).
  $\boldsymbol{w}^{\boldsymbol{t+1}} \leftarrow \boldsymbol{w}^{\boldsymbol{t}} + \eta * g^{t+1}$
  PS send $\boldsymbol{w}^{\boldsymbol{t+1}}$ to all users.
end for
return $\boldsymbol{w}^{\boldsymbol{T}}$

the AS collaboratively run the *SecureMedian* protocol to compute the coordinate-wise median of all encrypted gradients, which serves as the benchmark gradient. Third, the PS and the AS execute the *SecureTrustScore* protocol to measure the layer-wise cosine similarity between each encrypted gradient and the benchmark. Finally, the PS and the AS employ the *SecureAggregation* protocol to update the global model by aggregating the encrypted gradients weighted by their trust scores.

C. Construction of SFLBR

1) Secure Computing Local Gradients: Without loss of generality, we take the t-th communication round as an example. The PS distributes the global model parameters $\boldsymbol{w}^t$ to all N users. Each user i uses its local dataset D_i to compute the local gradient based on $\boldsymbol{w}^t$. Specifically, user i partitions D_i into $\mathcal{B}$ mini-batches of size B. For each mini-batch $b \in \mathcal{B}$, user i updates the local model parameters by performing stochastic gradient descent (SGD) [28] on the training loss. After processing all mini-batches, user i obtains an updated local model $\boldsymbol{w}_i^{t+1}$ and computes the local gradient as $\boldsymbol{g}_i^{t+1} = \boldsymbol{w}_i^{t+1} - \boldsymbol{w}^t$.

It is worth noting that the training loss consists of the cross-entropy (CE) loss and a regularization term. The CE loss

Implementation of *LocalTrain*(i, t, $\boldsymbol{w}^t$)

Input: User id i, communication round t, global model $\boldsymbol{w}^t$.
Output: Local encrypted gradient $[\boldsymbol{g}_i^{t+1}]$.
Procedure:
User i:
1. Sets the size of small batch training data B.
2. Divides the dataset D_i into multiple batches $\mathcal{B}$ by B.
3. For $(x, y) \in b$, where b in $\mathcal{B}$, computing loss:
   $loss = \alpha||\boldsymbol{w}^t - \boldsymbol{w}_i^{t+1}||_2 + CE(y, \boldsymbol{w}_i^{t+1}(x))$.
   Backpropagation update the $\boldsymbol{w}_i^t$ based on $loss$.
4. Computes the local gradient: $\boldsymbol{g}_i^{t+1} = \boldsymbol{w}_i^{t+1} - \boldsymbol{w}^t$.
5. Randomly select two real number as secret key: $sk_i^1 \in \mathbb{R}$, $sk_i^2 \in \mathbb{R}$.
6. Uses PRG to generate double masks with sk_i^1 and sk_i^2 as a parameter.
7. Divides the gradient $\boldsymbol{g}_i^{t+1}$ into two parts with double mask:
   $[\boldsymbol{g}_i^{t+1}]_1 = \boldsymbol{g}_i^{t+1} + PRG(sk_i^1)$,
   $[\boldsymbol{g}_i^{t+1}]_2 = \boldsymbol{g}_i^{t+1} \odot PRG(sk_i^2)$.
8. Sends $[\boldsymbol{g}_i^{t+1}]_1$ and $[\boldsymbol{g}_i^{t+1}]_2$ to PS, sk_i^1 and sk_i^2 to AS.

Fig. 3. Secure local gradient computation protocol.

enables the local model to learn local knowledge. Motivated by **Motivation 2**, we design the regularization loss to proactively embed identifiable signals into the local model, facilitating the subsequent differentiation of malicious gradients. Specifically, under Non-IID scenarios, honest gradients diverge more substantially in direction, causing traditional robust aggregation based on cosine similarity to fail. To address this, we augment the local optimization objective with an additional regularization term that constrains excessive directional divergence among honest gradients, thereby restoring the effectiveness of robust aggregation. This regularization term is computed as the L2 distance of the difference between the local and global models, $\|\boldsymbol{w}_i^{t+1} - \boldsymbol{w}^t\|_2$, scaled by a constant α to control its magnitude. On the one hand, this term encourages local models to be directionally consistent, which promotes convergence of the global model. On the other hand, and more importantly, it reduces the divergence of local gradients, thereby enhancing the distinguishability of malicious gradients in Non-IID scenarios.

Recent work [4], [5] has demonstrated that gradients can leak user privacy. To address this, we design a lightweight dual-masking encryption mechanism that minimizes additional computation overhead while protecting user gradients. Specifically, we ensure gradient privacy through a simple and efficient approach based on element-wise matrix addition and multiplication. We use '+' and '−' to denote element-wise addition and subtraction, and '⊙' and '/' to denote element-wise multiplication and division, respectively. We employ a pseudo-random generator (*PRG*) [29] that takes a uniformly random seed as input and produces an output with the same dimensionality as the gradient space; the output of the *PRG* follows a uniform distribution $\mathcal{U}(-10, 10)$. To protect its local gradient, each user i uniformly samples two random seeds (sk_i^1, sk_i^2) and splits the gradient into two parts using element-wise operations: $[\boldsymbol{g}_i^{t+1}]_1 = \boldsymbol{g}_i^{t+1} + PRG(sk_i^1)$, $[\boldsymbol{g}_i^{t+1}]_2 = \boldsymbol{g}_i^{t+1} \odot PRG(sk_i^2)$. This encryption achieves semantic security due to the large seed space (the seed is drawn from $\mathbb{R}$) and the pseudo-randomness and unpredictability of the *PRG*.

Authorized licensed use limited to: Anhui University. Downloaded on October 10,2026 at 11:47:06 UTC from IEEE Xplore. Restrictions apply.

Implementation of *SecureMedian*($[\boldsymbol{g}_1^{t+1}]$,…, $[\boldsymbol{g}_N^{t+1}]$)

Input: Encrypted local gradient $[\boldsymbol{g}_1^{t+1}]_2$,…, $[\boldsymbol{g}_N^{t+1}]_2$.
Output: Encrypted median gradient $[\boldsymbol{g}_{med}^{t+1}]$.
Procedure:
PS:
1. Randomly initialize a Gaussian noise R with the same dimension as the gradient in the real number field.
2. Computes: $\left\{\boldsymbol{R}\odot[\boldsymbol{g}_i^{t+1}]_2 \middle| 1 \le i \le N\right\}$.
3. Sends $\left\{\boldsymbol{R}\odot[\boldsymbol{g}_i^{t+1}]_2 \middle| 1 \le i \le N\right\}$ to AS.

AS:
1. Removes local gradient's sk_i^2 mask use PRG, computes: $\boldsymbol{R}\odot[\boldsymbol{g}_i^{t+1}]_2/PRG(sk_i^2)$, obtains $\{\boldsymbol{R}\odot\boldsymbol{g}_i^{t+1} | 1 \le i \le N\}$.
2. According to $\{\boldsymbol{R}\odot\boldsymbol{g}_i^{t+1} | 1 \le i \le N\}$, for each element of the gradient vector, select the median from all gradients to form the benchmark gradient $\boldsymbol{R}\odot\boldsymbol{g}_{med}^{t+1}$.
3. Randomly initialize a Gaussian noise $\boldsymbol{R}'$ with the same dimension as the gradient in the real number field.
4. Computes: $\boldsymbol{R}'\odot\boldsymbol{R}\odot\boldsymbol{g}_{med}^{t+1}$, sends it to PS.

PS:
1. Removes noise R, computes: $\boldsymbol{R}'\odot\boldsymbol{R}\odot\boldsymbol{g}_{med}^{t+1}/\boldsymbol{R} = \boldsymbol{R}'\odot\boldsymbol{g}_{med}^{t+1}$. Lets $[\boldsymbol{g}_{med}^{t+1}] = \boldsymbol{R}'\odot\boldsymbol{g}_{med}^{t+1}$.

Fig. 4. Secure gradient median computation protocol.

To enable secure and effective Byzantine-robust aggregation in subsequent steps, each user i sends the encrypted gradients $[\boldsymbol{g}_i^{t+1}]_1$ and $[\boldsymbol{g}_i^{t+1}]_2$ to the PS. Meanwhile, user i establishes a TLS/SSL [30] secure channel with the AS and transmits the dual secret seeds sk_i^1 and sk_i^2, ensuring that the seeds cannot be eavesdropped by external adversaries. Consequently, the PS receives $2N$ encrypted gradients and the AS receives $2N$ secret seeds. The details are illustrated in Fig. 3.

2) Byzantine-Robust Aggregation: The non-colluding dual servers, PS and AS, jointly perform Byzantine-robust aggregation while preserving the confidentiality of user gradients. It is essential that during this computation, neither server is able to compromise user privacy based solely on the information accessible to it.

a) Secure computing gradient median: To distinguish malicious from honest gradients among the encrypted gradients, an effective reference benchmark is essential, complementing the proactive injection of identifiable signals. The benchmark acts as an anchor: gradients close to it are likely honest, while those that deviate substantially are likely malicious. Motivated by **Motivation 1**, we adopt the element-wise gradient median as this benchmark. During the median computation, the PS and AS jointly leverage element-wise operations to encrypt intermediate results, thereby preserving user privacy. Since the AS holds the users' secret seeds, the PS secondarily encrypts the encrypted gradients $\{\boldsymbol{R}\odot[\boldsymbol{g}_i^{t+1}]_2 | 1 \le i \le N\}$ using a unified Gaussian noise $\boldsymbol{R}$ before transmitting it to AS. The dimension of $\boldsymbol{R}$ is the same as the gradient space and the probability distribution follows $\mathcal{N}(0, 10^2)$. This step prevents the AS from compromising user gradients. Using its knowledge of the secret seeds $\{(sk_i^1, sk_i^2) \mid 1 \le i \le N\}$, the AS then removes the corresponding user masks and obtains $\{\boldsymbol{R}\odot\boldsymbol{g}_i^{t+1} \mid 1 \le i \le N\}$. Because the identical noise $\boldsymbol{R}$ is applied across all local gradients, the element-wise median is unaffected by $\boldsymbol{R}$, i.e., $\boldsymbol{R}\odot MED(\{\boldsymbol{g}_i^{t+1}\}_{i=1}^N) = MED(\{\boldsymbol{R}\odot\boldsymbol{g}_i^{t+1}\}_{i=1}^N)$, where MED returns the coordinate-wise median of a set of vectors. Consequently, the AS obtains the masked median $\boldsymbol{R}\odot\boldsymbol{g}_{med}^{t+1}$, with $\boldsymbol{g}_{med}^{t+1} = MED(\{\boldsymbol{g}_i^{t+1}\}_{i=1}^N)$. To conceal the median from the PS, the AS samples another independent Gaussian noise $\boldsymbol{R}'$ (following the same distribution $\mathcal{N}(0, 10^2)$) and applies it to the masked median, producing $\boldsymbol{R}'\odot\boldsymbol{R}\odot\boldsymbol{g}_{med}^{t+1}$. The AS returns this doubly-masked result to the PS. Since the PS knows $\boldsymbol{R}$, it removes this mask through element-wise division, yielding the encrypted median $[\boldsymbol{g}_{med}^{t+1}] = \boldsymbol{R}'\odot\boldsymbol{g}_{med}^{t+1}$. The details of this protocol are illustrated in Fig. 4.

b) Secure computing gradient trust scores: Achieving Byzantine-robust aggregation is particularly challenging in Non-IID settings, where data heterogeneity induces substantial divergence among honest gradients, further obscuring the distinction between honest and malicious updates. Earlier, we employed a proactive defense to constrain this divergence. Here, we incorporate the gradient median as a benchmark to further strengthen robustness. Concretely, we compute the layer-wise cosine similarity between each encrypted gradient and the gradient median to magnify their differences, and design an effective trust score function that converts the resulting similarity into a trust score.

The trust score of each gradient is computed from its encrypted version and the gradient median. To protect user privacy, the PS uniformly samples $2m$ random positive scalars from $\mathcal{U}(0, 10)$, denoted as $r^1 = \{r_j^1 \mid 1 \le j \le m\}$ and $r^2 = \{r_j^2 \mid 1 \le j \le m\}$, where m is the number of layers in the gradient. Before sending $[\boldsymbol{g}_i^{t+1}]_2$ and $[\boldsymbol{g}_{med}^{t+1}]$ to the AS, the PS applies a layer-wise masking: it multiplies each layer of $[\boldsymbol{g}_i^{t+1}]_2$ by r_j^1 and each layer of $[\boldsymbol{g}_{med}^{t+1}]$ by r_j^2, obtaining $r^1 * [\boldsymbol{g}_i^{t+1}]_2$ and $r^2 * [\boldsymbol{g}_{med}^{t+1}]$. Upon receiving these, the AS removes the user mask using the seed sk_i^2, and strips the noise mask using $\boldsymbol{R}'$, yielding $r^1 * \boldsymbol{g}_i^{t+1}$ and $r^2 * \boldsymbol{g}_{med}^{t+1}$. Although each gradient layer remains encrypted by the random factors r_j^1 and r_j^2, layer-wise cosine similarity is invariant to such scaling. For example, when calculating the j-th layer consie similarity $cos(r_j^1 * \boldsymbol{g}_i^{t+1}[j], r_j^2 * \boldsymbol{g}_{med}^{t+1}[j])$, the following equation holds:

$$\frac{< r_j^1 * \boldsymbol{g}_i^{t+1}[j], r_j^2 * \boldsymbol{g}_{med}^{t+1}[j] >}{\|r_j^1 * \boldsymbol{g}_i^{t+1}[j]\|_2 * \|r_j^2 * \boldsymbol{g}_{med}^{t+1}[j]\|_2} = \frac{< \boldsymbol{g}_i^{t+1}[j], \boldsymbol{g}_{med}^{t+1}[j] >}{\|\boldsymbol{g}_i^{t+1}[j]\|_2 * \|\boldsymbol{g}_{med}^{t+1}[j]\|_2}. \quad (1)$$

The notation $\boldsymbol{g}_i^{t+1}[j]$ represents the j-th layer of $\boldsymbol{g}_i^{t+1}$. The calculated similarity for the j-th layer between $\boldsymbol{g}_i^{t+1}$ and $\boldsymbol{g}_{med}^{t+1}$ is denoted as μ_i^j. Since cosine similarity ranges from -1 to 1, we further introduce a segmented function to calculate the trust score corresponding to the similarity, as follow:

$$scoreFunc(\mu) = \begin{cases} (\mu+1)^2, & -1 \le \mu \le 0 \\ \mu + 1, & 0 < \mu \le 1 \end{cases} \quad (2)$$

After obtaining the per-layer scores μ_i^j, the AS computes each user's overall trust score as $\mu_i = \sum_{j=1}^m \mu_i^j$. To improve the stability of the aggregation, the AS normalizes all scores

Authorized licensed use limited to: Anhui University. Downloaded on October 10,2026 at 11:47:06 UTC from IEEE Xplore. Restrictions apply.

Implementation of *SecureTrustScore*($[\boldsymbol{g}_i^{t+1}]$, $[\boldsymbol{g}_{med}^{t+1}]$)

Input: Encrypted local and median gradient $[\boldsymbol{g}_i^{t+1}]_2$, $[\boldsymbol{g}_{med}^{t+1}]$.
Output: Trust score of local gradient ρ_i.
Procedure:
PS:
1. Randomly select $2m$ random numbers $\{r_j^1 | 1 \le j \le m\}$ and $\{r_j^2 | 1 \le j \le m\}$ from real number field.
2. For $j \in [1, m]$, multiply j-th layer by a random number: $[\boldsymbol{g}_i^{t+1}]_2[j] *= r_j^1$, $[\boldsymbol{g}_{med}^{t+1}][j] *= r_j^2$. Record the result as $r^1 * [\boldsymbol{g}_i^{t+1}]_2$, $r^2 * [\boldsymbol{g}_{med}^{t+1}]$.
3. Sends $r^1 * [\boldsymbol{g}_i^{t+1}]_2$ and $r^2 * [\boldsymbol{g}_{med}^{t+1}]$ to AS.

AS:
1. Removes local gradient's sk_i^2 mask use PRG, computes: $r^1 * \boldsymbol{g}_i^{t+1} = r^1 * [\boldsymbol{g}_i^{t+1}]_2 / PRG(sk_i^2)$.
2. Removes noise of median gradient, computes: $r^2 * \boldsymbol{g}_{med}^{t+1} = r^2 * [\boldsymbol{g}_{med}^{t+1}] / \boldsymbol{R}'$.
3. For $j \in [1, m]$, computes similarity by layer: $\mu_i^j = cos(r_j^1 * \boldsymbol{g}_i^{t+1}[j], r_j^2 * \boldsymbol{g}_{med}^{t+1}[j])$. $\mu_i^j = scoreFunc(\mu_i^j)$. $\mu_i += \mu_i^j$.

Fig. 5. Secure gradient trust scores computation protocol.

to $\rho_i = \frac{\mu_i}{\sum_{i=1}^N \mu_i}$ and transmits $\{\rho_i | 1 \le i \le N\}$ to the PS. It is important to highlight how *scoreFunc* converts a layer-wise cosine similarity into a positive value to further enhance the robustness of SFLBR in Non-IID scenarios. This design is motivated by three practical considerations. First, for honest gradients with a similarity greater than 0, the function simply uses a linear shift $\mu + 1$, preserving the relative ordering and magnitude of honest contributions. For a similarity less than 0, which often indicates a malicious deviation, the function applies $(\mu+1)^2$; since $\mu+1 \in (0, 1)$ in this case, squaring drives the score closer to zero, thereby weakening gradients that are highly dissimilar to the benchmark. Second, even with proactive defense strategy, honest gradients in Non-IID settings can occasionally exhibit mildly negative similarities; using a hard threshold (e.g., zeroing out any negative similarity) would discard useful information and severely slow convergence. Third, real-world FL systems are often clean, i.e., free of malicious users, and a hard zeroing rule would unnecessarily disrupt training, whereas our soft down-weighting scheme remains convergent in both adversarial and benign environments. The specific protocol is outlined in Fig. 5.

c) Secure aggregating global gradient: After executing the *SecureTrustScore* protocol, both the PS and the AS hold the normalized trust scores $\{\rho_i | 1 \le i \le N\}$ for all user gradients. These scores serve as the aggregation weights. To securely compute the global gradient, the PS first computes a weighted sum of the encrypted gradients $\{[\boldsymbol{g}_i^{t+1}]_1 | 1 \le i \le N\}$ using the trust scores, yielding the encrypted global gradient $[\boldsymbol{g}^{t+1}] = \sum_{i=1}^N \rho_i * [\boldsymbol{g}_i^{t+1}]_1$. Recall that each $[\boldsymbol{g}_i^{t+1}]_1$ is encrypted via element-wise addition with a mask $PRG(sk_i^1)$. Consequently, $[\boldsymbol{g}^{t+1}] = \sum_{i=1}^N \rho_i \boldsymbol{g}_i^{t+1} + \sum_{i=1}^N \rho_i * PRG(sk_i^1)$, which remains encrypted under the combined seeds $\{sk_i^1 | 1 \le i \le N\}$. The PS then transmits $[\boldsymbol{g}^{t+1}]$ to the AS. Since the AS possesses all secret seeds and the corresponding trust scores, it can locally compute the aggregate mask $\sum_{i=1}^N \rho_i * PRG(sk_i^1)$ and subtract

Implementation of *SecureAggregation*($\rho_1, \ldots, \rho_N$; $[\boldsymbol{g}_1^{t+1}], \ldots, [\boldsymbol{g}_N^{t+1}]$)

Input: Trust score and encrypted local gradient $\rho_1, \ldots, \rho_N$; $[\boldsymbol{g}_1^{t+1}]_1, \ldots, [\boldsymbol{g}_N^{t+1}]_1$.
Output: Global gradient $\boldsymbol{g}^{t+1}$.
Procedure:
PS:
1. According to encrypted local gradient and its trust score, performs weighted aggregation: $[\boldsymbol{g}^{t+1}] = \sum_{i=1}^N \rho_i * [\boldsymbol{g}_i^{t+1}]_1$.
2. Sends $[\boldsymbol{g}^{t+1}]$ to AS.

AS:
1. Removes all local gradient's sk_i^1 mask use PRG from $[\boldsymbol{g}^{t+1}]$, computes: $g^{t+1} = [\boldsymbol{g}^{t+1}] - \sum_{i=1}^N \rho_i * PRG(sk_i^1) = \sum_{i=1}^N \rho_i * \boldsymbol{g}_i^{t+1}$.
2. Sends $\boldsymbol{g}^{t+1}$ to PS.

Fig. 6. Secure gradient aggregation protocol.

it from $[\boldsymbol{g}^{t+1}]$, thereby recovering the plaintext global gradient $\boldsymbol{g}^{t+1}$. Finally, the AS sends $\boldsymbol{g}^{t+1}$ back to the PS. The detailed workflow of this protocol is illustrated in Fig. 6.

At this point, the Byzantine-robust aggregation for encrypted gradients is complete. The PS utilizes the global gradient $\boldsymbol{g}^{t+1}$ to update the global model:

$$\boldsymbol{w}^{t+1} = \boldsymbol{w}^t + \eta * \boldsymbol{g}^{t+1}, \tag{3}$$

where $\boldsymbol{w}^{t+1}$ is the global model of $(t+1)$-th round, and η is the global learning rate. Finally, PS sends the new global model $\boldsymbol{w}^{t+1}$ to all users.

V. Theoretical Analysis

A. Security Analysis

By ensuring the security of the *PRG* and the randomness and privacy of the secret seeds, the dual-masking encryption mechanism achieves semantic security, which also ensures strong security during the operation of the SFLBR protocol. In this section, we consider honest-but-curious dual servers and malicious users. Each server combines its existing knowledge to infer user privacy, while malicious users upload malicious gradients. We provide a hybrid argument that bases on a simulator to further demonstrate that during the execution of the protocol, dual servers leak nothing about the user privacy.

Proposition 1 (SFLBR Security, With Honest-But-Curious Dual Servers): Given a security parameter κ, any subset of users U and dual servers C ={PS, AS}. Let the random variable REAL denote the real view of PS and AS during protocol execution. When PRG is pseudo-random and encryption mechanism is semantically secure, there exists a probability polynomial time (PPT) simulator SIM, whose output is computationally indistinguishable from REAL, as follows:

$$\mathrm{SIM}_C^{U,\kappa} \approx_c \mathrm{REAL}_C^{U,\kappa}, \tag{4}$$

where '$\approx_c$' represents computationally indistinguishable.

Proof: See APPENDIX A. □

The above proves that honest-but-curious dual servers do not leak honest user privacy without collusion. Below, we prove

Authorized licensed use limited to: Anhui University. Downloaded on October 10,2026 at 11:47:06 UTC from IEEE Xplore. Restrictions apply.

that malicious or honest-but-curious users also cannot leak the privacy of honest users.

Proposition 2: Malicious or honest-but-curious users cannot compromise the privacy of other honest users.

Proof: See APPENDIX B. □

B.: Convergence Analysis

We provide a proof of convergence for the SFLBR scheme below. According to section IV-C1, we know that the loss function of user i is $F_i(\boldsymbol{w}_i) = CE(\cdot) + \alpha\|\boldsymbol{w}_i - \boldsymbol{w}\|_2$. We make the following assumptions:

Assumption 1: For loss function of user i, $F_i(\boldsymbol{w}_i)$ is L-smooth, i.e. for any model parameter $\boldsymbol{w}_i^1$ and $\boldsymbol{w}_i^2$, there are:$F_i(\boldsymbol{w}_i^1) \leq F_i(\boldsymbol{w}_i^2) + (\boldsymbol{w}_i^1 - \boldsymbol{w}_i^2)^T\nabla F_i(\boldsymbol{w}_i^2) + \frac{L}{2}\|\boldsymbol{w}_i^1 - \boldsymbol{w}_i^2\|_2$.

Assumption 2: For loss function of user i, $F_i(\boldsymbol{w}_i)$ is μ-strongly convex, i.e. for any model parameter $\boldsymbol{w}_i^1$ and $\boldsymbol{w}_i^2$ of user i, there are: $F_i(\boldsymbol{w}_i^1) \geq F_i(\boldsymbol{w}_i^2) + (\boldsymbol{w}_i^1 - \boldsymbol{w}_i^2)^T\nabla F_i(\boldsymbol{w}_i^2) + \frac{\mu}{2}\|\boldsymbol{w}_i^1 - \boldsymbol{w}_i^2\|_2$.

Assumption 3: The variance of the user i's local gradient trained using local data D_i is bounded: $\mathbb{E}(\|\nabla F_i(\boldsymbol{w}_i, D_i) - \nabla F_i(\boldsymbol{w}_i)\|_2^2) \leq \sigma_i^2$.

Assumption 4: The user i's local gradient norm trained using local data D_i is bounded: $\mathbb{E}(\|\nabla F_i(\boldsymbol{w}_i, D_i)\|_2^2) \leq G^2$.

In addition, let F^* be the optimal solution of the global loss function F, F_i^* be the optimal solution of local loss function F_i. We define $\Gamma = \sum_{i=1}^N \rho_i F_i^* - F^*$. Γ is used to measure the extent of Non-IID, when $\Gamma = 0$, i.e. the training data are IID. Furthermore, we define $\overline{\boldsymbol{w}}^t = \sum_{i=1}^N \rho_i \boldsymbol{w}_i^t$, $\boldsymbol{g}^t = \sum_{i=1}^N \rho_i \nabla F_i(\boldsymbol{w}_i^t, D_i)$ and $\overline{\boldsymbol{g}}^t = \sum_{i=1}^N \rho_i \nabla F_i(\boldsymbol{w}_i^t)$. We assume each communication round has E local epochs. SFLBR trains the global model w^T after T rounds. To prove the convergence of the scheme, we first establish the following three lemmas:

Lemma 1: If assumptions 1 and 2 hold, learning rate meets $lr^1 \leq \frac{1}{4L}$ and $lr^t \leq 2lr_{t+E}$. The following formula is hold: $\mathbb{E}(\|\overline{\boldsymbol{w}}^{t+1} - \boldsymbol{w}^*\|^2) \leq (1 - \mu lr^t)\mathbb{E}(\|\overline{\boldsymbol{w}}^t - \boldsymbol{w}^*\|^2) + (lr^t)^2\mathbb{E}(\|\boldsymbol{g}^t - \overline{\boldsymbol{g}}^t\|^2) + 6L(lr^t)^2\Gamma + 2\mathbb{E}\left(\sum_{i=1}^N \rho_i\|\overline{\boldsymbol{w}}^t - \boldsymbol{w}_i^t\|^2\right)$.

Lemma 2: If assumptions 3 hold, the following formula is hold:$\mathbb{E}(\|\boldsymbol{g}^t - \overline{\boldsymbol{g}}^t\|^2) \leq \sum_{i=1}^N \rho_i^2\sigma_i^2$.

For the proof of Lemmas 1 and 2, see [31].

Lemma 3: If assumptions 4 hold, and learning rate meets $lr^t \leq 2lr^{t+E}$. the following formula is hold:$\mathbb{E}\left(\sum_{i=1}^N \rho_i\|\overline{\boldsymbol{w}}^t - \boldsymbol{w}_i^t\|^2\right) \leq 4(lr^t)^2(E-1)^2G^2$.

Proof: See APPENDIX C. □

Theorem 1: If assumptions 1-4 hold and the relevant parameters L, μ, σ_i and G are given. Meanwhile, t-round learning rate lr^t dose not increases. It can be proven that there is an upper bound on the difference between the expectation of the global loss function $\mathbb{E}(F(\boldsymbol{w}^T))$ in round T and its optimal solution $F^*(\boldsymbol{w}^T)$. This upper bound decreases as T increases, i.e., the scheme is convergent, as follows:

$$\mathbb{E}(F(\boldsymbol{w}^T)) - F^*(\boldsymbol{w}^T) \leq \Phi(T), \tag{5}$$

where $\Phi(T)$ will decrease as T increases.

Proof: According to L-smoothness assumption, we obtain:

$$\mathbb{E}(F(\boldsymbol{w}^T) - F^*(\boldsymbol{w}^T) \leq \frac{L}{2}\mathbb{E}(\|\boldsymbol{w}^T - \boldsymbol{w}^*\|^2). \tag{6}$$

Using the above lemma 1- 3, we can prove that $\mathbb{E}(F(\boldsymbol{w}^T) - F^*(\boldsymbol{w}^T))$ has an upper bound, i.e., SFLBR can converge in IID or Non-IID scenarios. □

C. Complexity Analysis

To analyze the efficiency of SFLBR, we introduce the following notation. Let N be the number of participating users and M the length of a flattened gradient. We denote by T_{PRG} the cost of one PRG operation, by T_{Add} and T_{Mul} the costs of element-wise addition/subtraction and element-wise multiplication/division on gradients, respectively, and by T_{Cos} the cost of computing layer-wise cosine similarity. For sorting a vector of length X, we assume the cost is $O(X \log X)$. The communication cost of transmitting a single gradient is $O(M)$. Notably, the encryption and decryption operations used in SFLBR are substantially cheaper than the exponentiation required in HE-based schemes [10]. For example, ShieldFL [10] must first convert gradients to integers (e.g., by scaling with a factor of 10^5) and then perform expensive exponentiation, which considerably increases the computational burden on the FL system.

Below is a specific analysis of the computational and communication cost of SFLBR. After *LocalTrain*, the users need to encrypt the local gradient, send encrypted gradients and dual secret seeds to PS and AS. The users incur a computational cost $O(2NT_{PRG} + NT_{Add} + NT_{Mul})$, and a communication cost $O(2NM+2N)$. In *SecureMedian*, PS sends all user gradients to AS, and AS calculates and returns the gradient median to PS. PS and AS incur a computational cost $O(2(N+1)T_{PRG}+2(N+1)T_{Mul} + MNlog(N))$, and a communication cost $O(NM + M)$. In *SecureTrustScore*, PS sends all user gradients and gradient median to AS, and AS calculates trust scores for user gradient and returns them to PS. PS and AS incur a computational cost $O(2(N+1)T_{Mul}+(N+1)T_{PRG}+NT_{Cos})$, and a communication cost $O((N + 1)M + N)$. In *SecureAggregation*, PS weights and aggregates all user gradients and sends it to AS, and AS decrypts and returns the raw aggregated gradient to PS. PS and AS incur a computational cost $O((2N - 1)T_{Add} + 2NT_{Mul} + NT_{PRG})$, and a communication cost $O(2M)$. Therefore, in one round of global communication for SFLBR, the system incur a computational cost $O((6N+3)T_{PRG} + (7N+4)T_{Mul} + (3N-1)T_{Add} + NT_{Cos} + MNlog(N))$, and a communication cost $O((4N + 4)M + 3N)$.

VI. Experiment

A. Experimental Configuration

1) Datasets and Models: We validate the effectiveness of our SFLBR using 3 real-world datasets, MNIST, CIFAR10 and CIFAR100. We use the Dirichlet distribution DirN(β) to simulate IID or Non-IID scenarios, with a smaller β indicating a higher degree of Non-IID.

a) MNIST: contains 10 categories, 60,000 training samples and 10,000 test samples. Each sample is a grayscale image with a size of 28×28. We design a simple model to learn the MNIST, consisting of two convolutional layers (kernels: 5×5) and two fully connected layers (dimensions: 320×50, 50×10).

Authorized licensed use limited to: Anhui University. Downloaded on October 10,2026 at 11:47:06 UTC from IEEE Xplore. Restrictions apply.

b) CIFAR10: contains 10 categories, 50,000 training samples and 10,000 test samples. Each sample is a three-channel color image with a size of $32 \times 32 \times 3$. We also design a model for CIFAR10, consisting of two convolutional layers (kernels: 5×5) and three fully connected layers (dimensions: 400×120, 120×84, 84×10).

c) Cifar100: contains 100 categories, 50,000 training samples and 10,000 test samples. Each sample is a three-channel color image with a size of $32 \times 32 \times 3$. Considering the complexity of CIFAR100, we use the residual network ResNet50 [32].

2) Defense Baselines: We use 7 Byzantine-robust aggregation algorithms as comparison baselines, namely FedAvg [1], Krum [18], Median [17], T-mean [17], ShieldFL [10], PEFL [9], and RFLPA [26]. To better showcase SFLBR, we set $\alpha = 0.01$, 0.005, and 0.001 for the regularization term on MNIST, CIFAR10, and CIFAR100, respectively.

3) Attacks and Metrics: We implement diverse Byzantine attacks, including standard label shuffling attack (LSA) [33] and more aggressive AGR [16] and ALIE [15] attacks, to comprehensively evaluate the defense performance of baselines. The evaluation metric is the prediction accuracy of the global model (ACC). Furthermore, we use Deep Gradient Leakage attack (DLG) [5] to evaluate the performance of SFLBR in privacy preservation.

4) Training Details: SFLBR and all baseline methods are implemented in Python using the PyTorch framework, and all experiments are conducted on an NVIDIA GeForce RTX 3090 GPU. The FL process spans 120 global communication rounds. In each round, the PS randomly selects 10 participating users, each of whom performs 3 local epochs of training. Local models are trained via SGD with a weight decay of 10^{-5}, momentum of 10^{-4}, and a batch size of 32. The initial learning rate is set to 0.1 and is decayed by a factor of 10 at the 40-th and 80-th global rounds.

B. Defense Performance Against LSA Attack

TABLE II reports the **highest accuracy** (ACC) achieved by different baselines across various settings.

1) Defense Performance to Different Malicious User Rates: To comprehensively evaluate the effectiveness of SFLBR under varying malicious user ratios (MR), we consider MR ranging from typically low to extremely high: 10%, 20%, 30%, 40%, 50%. Taking the IID scenario ($\beta = 100$) as a representative example, the following observations can be made. Under low MR (10%-30%), SFLBR outperforms FedAvg by up to 2.48% on MNIST, 8.26% on CIFAR-10, and 3.77% on CIFAR-100, and it also consistently surpasses the other baselines, demonstrating its strong defense capability under typically low MR. Under high MR (40%-50%), SFLBR likewise achieves robust defense performance, with maximum improvements over FedAvg of 6.69%, 11.90%, and 11.59% on MNIST, CIFAR-10, and CIFAR-100, respectively, again noticeably exceeding the other baselines and confirming its optimal Byzantine robustness under extremely attack scenarios. The consistent superiority of SFLBR across all MR levels stems from its use of the gradient median as a benchmark for distinguishing malicious updates. From a statistical perspective, as long as the malicious user ratio remains below 50%, the median inherently aligns with the honest gradients; consequently, SFLBR reliably assigns higher trust scores to honest gradients and effectively suppresses malicious ones.

In addition, we verify the convergence behavior of SFLBR in a clean setting (MR= 0%), observing that it does not degrade the performance of the global model, which further strengthens its practical applicability.

2) Defense Performance to Different Data Scenarios: We further evaluate SFLBR under varying degrees of data heterogeneity, including an IID setting ($\beta = 100$) and Non-IID settings with $\beta = 0.5$ and $\beta = 0.05$. We focus on the most challenging case of a high malicious rate (MR= 50%) for analysis. In the IID scenario, SFLBR achieves satisfactory Byzantine robustness across all three datasets, as the gradient median can effectively separate honest and malicious gradients. Under the extreme Non-IID setting ($\beta = 0.05$), SFLBR again demonstrates strong defense performance, outperforming FedAvg by 3.94% on MNIST and 10.65% on CIFAR-10, and surpassing the second-best baseline by 2.40% and 4.17%, respectively. The poor performance of FedAvg results from the simultaneous impact of a high MR and severe data heterogeneity. The core difficulty for SOTA defense baselines under Non-IID settings lies in the increased confusion between honest and malicious gradients. In contrast, SFLBR addresses this challenge in two ways. First, it employs a proactive defense strategy that actively constrains honest gradients during local training, preventing them from diverging excessively. Second, it adopts a segmented trust score function to effectively reduce the risk of misclassifying honest gradients as malicious. As a result, SFLBR achieves effective Byzantine-robust aggregation even under highly Non-IID scenarios.

C. Analysis

1) Analysis for Communication Rounds: As training proceeds, the global model gradually converges. Fig. 7 shows how ACC evolves over communication rounds at a high MR of 50%. In the IID setting, SFLBR exhibits stable convergence, whereas Median and ShieldFL show considerable instability—particularly on CIFAR10, where their accuracy fluctuates heavily and ShieldFL even fails to converge in later rounds. In terms of ACC, SFLBR performs comparably to the baselines on MNIST while significantly outperforming them on CIFAR10, also with noticeably faster convergence. We further analyze the effect of communication rounds in Non-IID settings. On MNIST, which all methods learn relatively easily, SFLBR maintains comparable ACC. On CIFAR10, its advantages become more pronounced: when $\beta = 0.5$, SFLBR reaches the same ACC within 40–60 rounds that competing schemes require 100–120 rounds to achieve. At $\beta = 0.05$, SFLBR attains 34% ACC by round 30 and 40% by round 90, whereas FedAvg achieves only 29% by round 110 and the other baselines need 80–100 rounds to reach 30%. These results indicate that SFLBR is particularly

Authorized licensed use limited to: Anhui University. Downloaded on October 10,2026 at 11:47:06 UTC from IEEE Xplore. Restrictions apply.

TABLE II
DEFENSE PERFORMANCE OF DIFFERENT SCHEMES IN RESISTING LSA IN IID OR NON-IID SCENARIOS

MR	0%			10%			20%			30%			40%			50%		
β	100	0.5	0.05	100	0.5	0.05	100	0.5	0.05	100	0.5	0.05	100	0.5	0.05	100	0.5	0.05
MNIST dataset																		
FedAvg	99.19	99.12	98.66	99.03	97.95	94.80	98.25	95.89	90.04	96.57	94.77	85.23	93.68	92.61	83.36	92.19	89.38	81.10
Krum	98.84	98.22	10.09	98.74	98.08	10.09	98.63	97.38	21.33	98.59	97.60	10.10	98.16	96.17	11.35	97.78	96.63	45.48
Median	99.09	98.98	97.89	99.04	98.98	86.16	99.10	98.86	85.72	98.87	98.70	80.28	98.91	98.48	76.07	98.80	**98.28**	77.06
T-mean	**99.21**	99.11	98.70	**99.19**	98.92	88.97	**99.11**	98.91	86.46	99.04	**98.72**	83.86	98.87	98.49	82.34	98.60	97.68	80.20
ShieldFL	98.74	98.83	98.13	98.99	98.67	**95.46**	98.90	98.68	**92.25**	98.76	98.46	87.42	98.68	98.38	84.47	98.62	97.78	82.84
PEFL	98.55	98.39	97.63	98.64	98.42	85.94	98.68	98.40	85.79	98.67	98.02	81.60	98.42	97.81	81.63	97.90	96.98	81.96
RFLPA	99.06	98.76	97.71	98.93	98.76	86.52	98.98	98.81	86.80	98.93	98.51	82.12	98.80	98.36	78.24	97.64	97.17	78.77
SFLBR	99.04	**99.19**	**98.79**	99.03	**99.08**	94.20	99.00	**98.96**	91.12	**99.05**	98.62	**88.94**	**99.06**	**98.64**	**88.76**	**98.88**	97.92	**85.04**
CIFAR10 dataset																		
FedAvg	69.64	66.39	56.82	66.08	64.84	48.41	61.58	60.81	44.94	60.37	57.64	41.35	55.23	52.29	34.72	52.46	51.34	29.61
Krum	66.93	52.73	23.71	63.46	47.34	22.21	60.99	47.18	15.17	58.42	22.32	13.58	56.47	22.27	20.10	54.76	36.07	22.74
Median	67.41	64.56	48.93	68.20	63.24	42.80	66.71	63.57	39.73	66.76	60.88	33.35	63.90	58.96	32.30	63.06	55.05	32.42
T-mean	**69.95**	**67.65**	57.66	67.91	65.75	48.64	67.11	64.20	43.64	64.10	61.08	39.16	63.69	58.80	34.80	59.50	50.82	31.66
ShieldFL	68.26	61.68	50.01	67.48	61.33	39.62	64.60	61.80	39.86	64.18	62.01	37.03	65.10	58.36	34.04	62.17	55.90	35.47
PEFL	60.62	58.44	48.14	61.79	59.19	42.04	60.49	58.95	38.86	60.25	56.57	34.62	57.29	53.20	34.97	55.16	48.80	36.09
RFLPA	67.28	63.71	46.28	66.53	62.56	42.19	65.93	61.77	39.77	62.51	59.48	32.28	61.57	58.08	31.06	55.49	49.36	30.81
SFLBR	68.98	66.37	**58.25**	**69.20**	**65.97**	**49.14**	**69.33**	**65.43**	**47.51**	**68.63**	**65.05**	**44.15**	**65.39**	**62.19**	**40.75**	**64.36**	**59.57**	**40.26**
CIFAR100 dataset																		
FedAvg	68.01	61.27	58.08	67.00	62.08	51.27	66.35	59.22	50.54	60.80	57.24	46.24	60.19	51.91	40.52	41.41	38.82	29.57
Krum	64.70	57.61	33.03	66.15	57.17	28.15	64.74	59.24	29.91	60.19	55.07	18.30	56.42	41.32	15.41	51.71	31.33	12.89
Median	69.76	67.11	51.66	67.60	65.95	48.25	65.78	62.28	44.87	61.88	59.43	40.31	55.57	**55.82**	34.62	49.52	45.89	29.07
T-mean	69.52	57.14	**59.37**	67.83	63.28	53.00	65.62	63.92	49.27	60.62	58.55	41.92	52.28	49.10	32.13	38.43	31.14	21.01
ShieldFL	1.010	1.000	1.550	1.240	0.910	1.400	1.130	0.930	1.060	0.960	1.150	1.010	1.020	0.960	1.180	0.980	0.940	1.120
PEFL	69.84	67.58	58.29	**68.36**	65.69	52.99	65.52	**64.64**	50.54	63.64	59.57	46.46	**61.05**	55.24	**40.81**	52.86	44.46	30.90
SFLBR	**70.22**	**67.92**	58.26	67.45	**66.09**	**53.59**	**67.07**	64.23	**50.80**	**64.57**	**60.87**	**46.96**	60.75	55.14	40.03	**53.00**	**46.26**	**31.47**

well suited for real-world applications with heterogeneous data. SFLBR reduces the degree of gradient divergence under Non-IID scenarios by constraining local model optimization during local training, resulting in more stable convergence and more effective poisoning defense.

2) Analysis for Trust Scores: The robustness of SFLBR against Byzantine attacks is rooted in its trust score assignment. We assign a distinct trust score to each user gradient based on its layer-wise cosine similarity to the gradient median. Notably, for gradients with negative similarity—common in Non-IID scenarios—we apply a quadratic transformation rather than discarding them outright.

To elucidate why SFLBR achieves superior Byzantine robustness, we visualize the average trust scores received by honest and malicious gradients under MR= 0.2 and 0.3, with $\beta = 100$ (IID) and $\beta = 0.5$ (Non-IID), as shown in Fig. 8. The results indicate that honest gradients consistently obtain higher and more stable trust scores than malicious ones. In the IID setting, the randomness of malicious gradients lowers their similarity to the median, leading to clearly lower scores. In Non-IID settings, although divergent honest gradients may resemble malicious ones, SFLBR still assigns trust scores effectively. As discussed, we deliberately avoid hard thresholding (e.g., directly zeroing out negative similarities) and instead use a soft suppression mechanism. This choice greatly reduces the risk of misjudging honest gradients as malicious in Non-IID scenarios, thereby enhancing the overall robustness of SFLBR.

D. Robustness Experiments

To better illustrate the advantages of SFLBR in real-world applications, we increase the complexity of FL by randomly selecting 10 from 50 users in each round, and equip malicious users with more aggressive Byzantine attacks. We simulate Non-IID scenarios ($\beta = 0.5$) because these settings are closer to the real world.

1) Robustness to ALIE Attack: ALIE [15] amplifies attack effectiveness by adding small-range perturbations to the mean of the malicious gradients, controlled by a maximum perturbation parameter z and the variance of the malicious gradients. In our experiments, we set $z = 1.5$.

Authorized licensed use limited to: Anhui University. Downloaded on October 10,2026 at 11:47:06 UTC from IEEE Xplore. Restrictions apply.

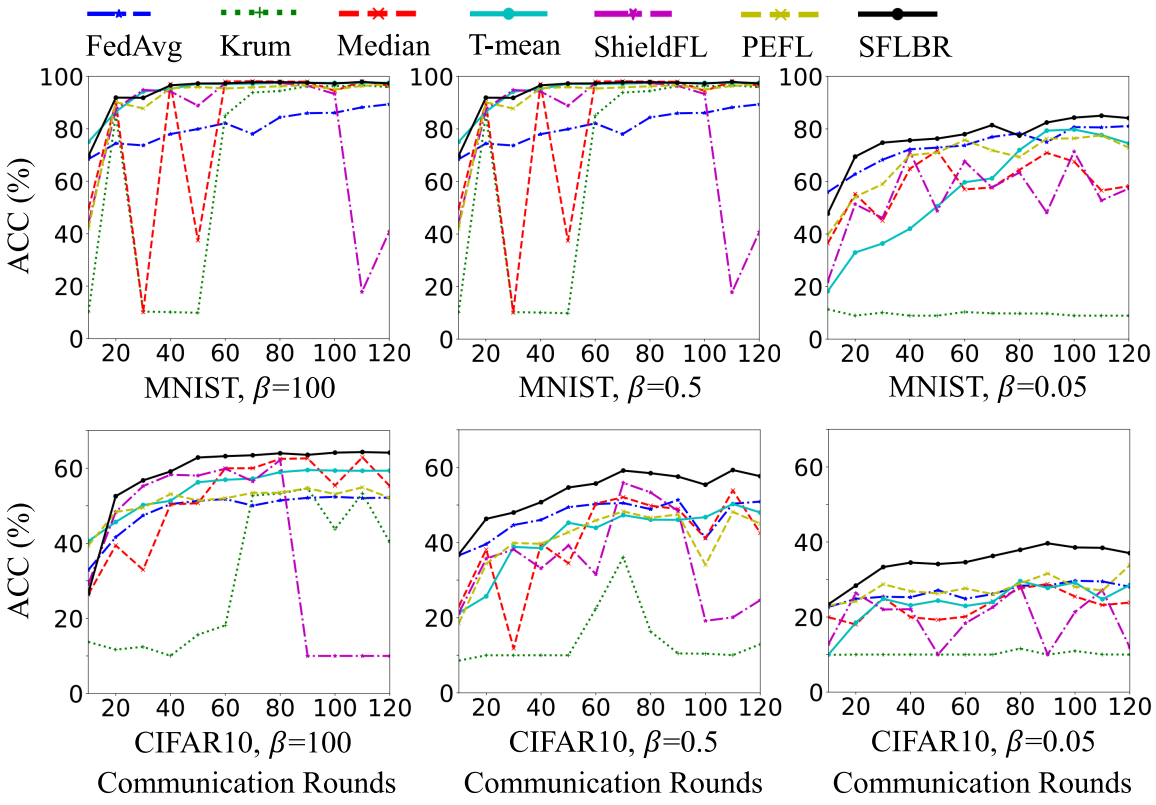


Fig. 7. Comparison of ACC under different communication rounds.

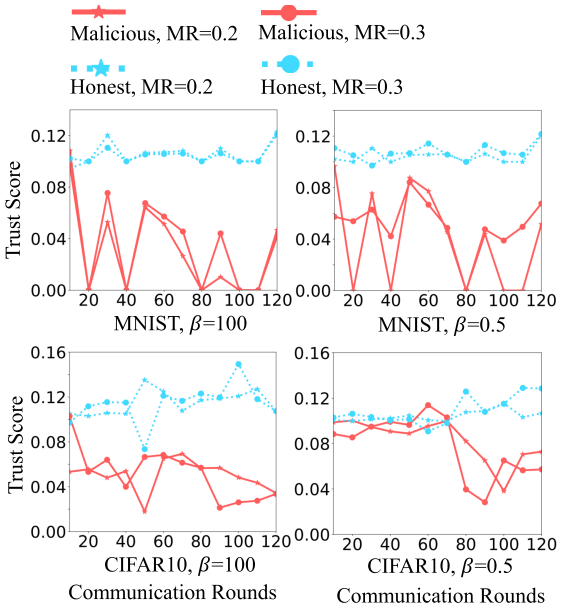


Fig. 8. Comparison of the average trust scores of honest and malicious gradients.

TABLE III
EFFECTIVENESS OF DIFFERENT BASELINES IN DEFENDING AGAINST ALIE ON CIFAR10 DATASET

MR	10%	20%	30%	40%	50%
Krum	41.32%	30.82%	16.84%	14.39%	10.00%
Median	49.51%	50.34%	43.45%	41.53%	24.39%
T-mean	51.05%	49.72%	44.77%	43.60%	34.65%
ShieldFL	47.64%	45.27%	44.76%	**43.74%**	35.29%
PEFL	50.95%	49.09%	40.67%	31.16%	20.71%
SFLBR	**52.29%**	**51.78%**	**45.43%**	41.63%	**36.12%**

TABLE III reports the **highest ACC** of different baselines under varying MR when facing ALIE. Notably, ALIE substantially strengthens Byzantine attacks through small-range perturbations, even in the presence of Byzantine-robust aggregation. Specifically, SFLBR achieves the highest ACC at most MR levels (10%, 20%, 30%, and 50%). At a high MR of 50%, SFLBR still attains 36.12% accuracy, outperforming the second-best ShieldFL by 0.83%. Moreover, under a low MR of 10%, SFLBR reaches 52.29% ACC. ALIE is clearly more destructive than conventional LSA, because all colluding malicious users transmit identical malicious gradients, thereby amplifying the attack. However, this strategy is ineffective against SFLBR. The reason is that employing identical malicious gradients does not undermine the proactive defense strategy; as long as the malicious gradient deviates from the honest ones and the malicious rate remains below 50%, the gradient median remains a reliable benchmark.

2) Robustness to AGR Attack: AGR [16] employs the unit vector opposite to the honest gradient direction as the malicious gradient unit, and formulates an optimization problem

Authorized licensed use limited to: Anhui University. Downloaded on October 10,2026 at 11:47:06 UTC from IEEE Xplore. Restrictions apply.

TABLE IV
EFFECTIVENESS OF DIFFERENT SCHEMES IN DEFENDING AGAINST AGR ON CIFAR10 DATASETS

MR	10%	20%	30%	40%	50%
Krum	31.85%	10.00%	10.00%	10.00%	10.00%
Median	48.62%	44.52%	28.95%	17.02%	10.00%
T-mean	51.93%	46.17%	35.34%	27.30%	**10.57%**
ShieldFL	46.11%	45.01%	27.28%	14.71%	10.00%
PEFL	52.07%	49.15%	41.71%	25.01%	10.00%
SFLBR	**52.40%**	**51.98%**	**44.79%**	**27.56%**	10.00%

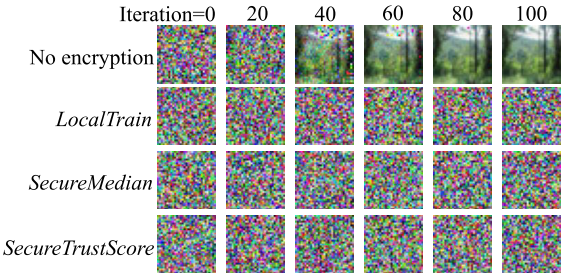


Fig. 9. The performance of SFLBR against DLG.

based on the distances among gradients to determine the optimal attack parameter λ.

TABLE IV reports the **highest ACC** of different baselines under varying MR when facing AGR. AGR consistently induces more severe ACC degradation than LSA and ALIE. At MR = 50%, nearly all defense schemes fail to withstand AGR; nevertheless, our SFLBR still attains the best robustness under this case. At MR = 30% and 40%, SFLBR outperforms the second-best baseline by 3.08% and 0.26%, respectively. When only a small fraction of users are malicious, the robust aggregation mechanism of SFLBR does not sacrifice ACC; for instance, SFLBR achieves the highest ACC of 52.40% and 51.98% at MR = 10% and 20%, respectively. AGR relies on a strong assumption (malicious users know the honest gradients) to craft maximally harmful malicious gradients, which grants it stronger attack capability. However, this very property also makes the malicious gradients easier to identify: since they point in the direction opposite to the honest gradients, their cosine similarity to the gradient median approaches -1, and they are consequently assigned lower trust scores.

E. Privacy Preservation Performance

We evaluate the privacy preservation of SFLBR using the DLG attack [5], which aims to reconstruct training data via gradient collision. We consider an honest-but-curious server (either PS or AS) that attempts to infer private information from the encrypted gradients it receives during the *LocalTrain*, *SecureMedian*, and *SecureTrustScore* protocols. Taking the CIFAR100 as an example, Fig. 9 shows the reconstruction results. It is evident that after 100 iterations of gradient collision, the raw (unencrypted) gradients can be successfully reconstructed, while SFLBR effectively prevents data leakage across all stages. Therefore, SFLBR is able to simultaneously defend against Byzantine attacks and preserve user privacy. A rigorous theoretical security proof is provided in Section V-A.

VII. CONCLUSION AND DISCUSSION

This paper addresses a persistent and unresolved challenge in FL. Although cryptographic techniques can protect the privacy of user gradients, they inadvertently provide a shield for injecting malicious gradients into the system. Moreover, existing defenses face notable limitations, particularly in Non-IID settings, where the natural divergence of honest gradients can easily be confused with malicious behavior.

To tackle these issues, we propose SFLBR, a Byzantine-robust secure FL scheme designed to mitigate the impact of Byzantine attacks on the global model. First, we introduce a regularization term based on the L2 distance between each user's local model and the global model, which proactively constrains excessive local gradient drift. Second, to better distinguish malicious gradients from honest ones, we compute layer-wise cosine similarities and derive a trust score for each gradient. Finally, these trust scores are used as aggregation weights for the local gradients. Crucially, all computations are carried out over encrypted gradients through a dual-masking encryption mechanism, ensuring that neither of the dual servers can compromise user privacy.

Although SFLBR achieves strong defense performance and efficiency both in theory and empirically, we remain cautious about its practical deployment security, as our evaluation is empirical and lacks formal certified guarantees. To further validate the applicability and effectiveness of SFLBR in real-world scenarios, we plan to deploy it in realistic FL environments in future work, systematically assessing its practical performance and generalization capability.

APPENDIX A

A. Proof of Proposition 1

Proof: The real view of dual servers $\mathtt{REAL}$ during protocol runtime should include the internal state of the dual servers (including inputs and randomness) as well as the messages they receive from other parties. We use a standard hybrid argument [9], [10] to demonstrate that $\mathtt{REAL}$ can be simulated when given their inputs and security parameter κ. i.e., the PPT simulator $\mathtt{SIM}$ proceeds through a series of (polynomially many) modifications to the random variables in $\mathtt{REAL}$, so that the output of $\mathtt{SIM}$ is computationally indistinguishable from $\mathtt{REAL}$. The detailed proof is described below.

$\mathtt{Hyb}_0$: This random variable is distributed exactly as $\mathtt{REAL}$, the joint view of the parties C in a real execution of the protocol.

$\mathtt{Hyb}_1$: In this hybrid, we simulate the behavior of honest users, so that instead of using $PRG(sk_i^1)$ and $PRG(sk_i^2)$, they uniformly random generate masks M_i^1 and M_i^2 to encrypt gradients and obtain $[X_i^{t+1}]_1 = \boldsymbol{g}_i^{t+1} + M_i^1$, $[X_i^{t+1}]_2 = \boldsymbol{g}_i^{t+1} \odot M_i^2$. Since we only replaced the pseudo random result of PRG with a real random number, PRG's pseudo randomness and the encryption scheme's semantic security setting guarantee $\mathtt{Hyb}_0 \approx_c \mathtt{Hyb}_1$.

Authorized licensed use limited to: Anhui University. Downloaded on October 10,2026 at 11:47:06 UTC from IEEE Xplore. Restrictions apply.

$\mathtt{Hyb}_2$: In this hybrid, we simulate the behavior of honest users, they uniformly random generate gradients Y_{i1}^{t+1}, Y_{i2}^{t+1} instead of $[X_i^{t+1}]_1$, $[X_i^{t+1}]_2$. Since the above variables are all uniform distribution, $\mathtt{Hyb}_1 \approx_c \mathtt{Hyb}_2$.

$\mathtt{Hyb}_3$: In this hybrid, we simulate PS to generate Gaussian noise β and uniformly random gradients Z_{i2}^{t+1} instead of R and Y_{i2}^{t+1}. Since β and R follow a Gaussian distribution, Z_{i2}^{t+1} and Y_{i2}^{t+1} follow a uniform distribution, the encryption scheme's semantic security and the non-collusive dual servers setting guarantee $\mathtt{Hyb}_2 \approx_c \mathtt{Hyb}_3$.

$\mathtt{Hyb}_4$: In this hybrid, we simulate AS to generate uniformly random noise ξ instead of $PRG(sk_i^2)$, computing $\beta \odot Z_{i2}^{t+1}/\xi$ instead of $\beta \odot Z_{i2}^{t+1}/PRG(sk_i^2)$. Meanwhile, we simulate AS to generate random gradient median P_{med}^{t+1} instead of honest gradient median. The PRG's pseudo randomness and encryption scheme's semantic security guarantee $\mathtt{Hyb}_3 \approx_c \mathtt{Hyb}_4$.

$\mathtt{Hyb}_5$: In this hybrid, we simulate AS to generate Gaussian noise ζ instead of R', computing $\zeta \odot P_{med}^{t+1}$ instead of $R' \odot P_{med}^{t+1}$ and send it to AS. Since ζ and R' follow a Gaussian distribution, the distribution of $\zeta \odot P_{med}^{t+1}$ and $R' \odot P_{med}^{t+1}$ is consistent. The encryption scheme's semantic security and the non-collusive dual servers setting guarantee $\mathtt{Hyb}_4 \approx_c \mathtt{Hyb}_5$.

$\mathtt{Hyb}_6$: In this hybrid, we simulate PS to generate Gaussian noise σ instead of β, computing $\zeta \odot P_{med}^{t+1}/\sigma$ instead of $\zeta \odot P_{med}^{t+1}/\beta$. Meanwhile, we simulate AS to generate random gradient median Q_{med}^{t+1} instead of $\zeta \odot P_{med}^{t+1}/\sigma$, and ensure consistent distribution between the above two. Since σ and β follow a Gaussian distribution, $\mathtt{Hyb}_5 \approx_c \mathtt{Hyb}_6$.

$\mathtt{Hyb}_7$: In this hybrid, we simulate PS to generate $2m$ random numbers α_j^1 and α_j^2 instead of r_j^1 and r_j^2, computing $\alpha^1 * Q_{med}^{t+1}$ and $\alpha^2 * Y_{i2}^{t+1}$ instead of $r^1 * Q_{med}^{t+1}$ and $r^2 * Y_{i2}^{t+1}$. Meanwhile, we simulate PS to generate random gradient S_{med}^{t+1} and V_{i2}^{t+1} instead of $\alpha^1 * Q_{med}^{t+1}$ and $\alpha^2 * Y_{i2}^{t+1}$, and ensure consistent distribution between the above variables. The non-collusive dual servers setting guarantee $\mathtt{Hyb}_6 \approx_c \mathtt{Hyb}_7$.

$\mathtt{Hyb}_8$: In this hybrid, we simulate AS to generate Gaussian noise ς and uniformly random ξ' instead of ζ and $PRG(sk_i^2)$, computing S_{med}^{t+1}/ς and V_{i2}^{t+1}/ξ' instead of S_{med}^{t+1}/ζ and $V_{i2}^{t+1}/PRG(sk_i^2)$. Since ς and ζ follow a Gaussian distribution, the PRG's pseudo randomness guarantee $\mathtt{Hyb}_7 \approx_c \mathtt{Hyb}_8$.

$\mathtt{Hyb}_9$: In this hybrid, we simulate AS to generate N random number σ_i instead of ρ_i. Since ρ_i is computed by S_{med}^{t+1}/ς and V_{i2}^{t+1}/ξ', ρ_i is a random number, $\mathtt{Hyb}_8 \approx_c \mathtt{Hyb}_9$.

$\mathtt{Hyb}_{10}$: In this hybrid, we simulate PS to generate uniformly random aggregation gradient G'_g instead of $\sum_{i=1}^N \sigma_i(Y_{i1}^{t+1})$ and send it to AS. Since σ_i and Y_{i1}^{t+1} are uniformly random, so G'_g and $\sum_{i=1}^N \sigma_i(Y_{i1}^{t+1})$ has a consistent distribution, $\mathtt{Hyb}_9 \approx_c \mathtt{Hyb}_{10}$.

$\mathtt{Hyb}_{11}$: In this hybrid, we simulate PS to generate uniformly random noise ϱ_i instead of $PRG(sk_i^{t+1})$, computing $G^{t+1} = G'_g - \sum_{i=1}^N \sigma_i(\varrho_i)$ and send it to PS. The PRG's pseudo randomness guarantee $\mathtt{Hyb}_{10} \approx_c \mathtt{Hyb}_{11}$.

Between any two hybrids mentioned above, the advantage $\mathtt{Adv}^{\mathtt{A}}_{\mathtt{Hyb}_i,\mathtt{Hyb}_{i+1}}$ of any PPT attacker $\mathtt{A}$ in distinguishing $\mathtt{Hyb}_i$ and $\mathtt{Hyb}_{i+1}$ is negligible, i.e., $\mathtt{Hyb}_i$ is computationally indistinguishable from $\mathtt{Hyb}_{i+1}$. The argument proves that there is a simulator $\mathtt{SIM}$ sampled from the distribution described above so that its output is computationally indistinguishable from the output of $\mathtt{REAL}$. Hence, SFLBR holds the security property that the curious PS and AS learn nothing about users' private data. □

B.: Proof of Proposition 2

Proof: After the t-th communication round, the user receives the global model parameter $\boldsymbol{w}^{t+1}$ from the PS. Therefore, malicious users can calculate the global gradient $\boldsymbol{g}^{t+1}$ for the t-th round based on $\boldsymbol{w}^{t+1}$ and the global model parameter $\boldsymbol{w}^t$ from the previous round, $\boldsymbol{g}^{t+1} = \boldsymbol{w}^{t+1} - \boldsymbol{w}^t$. However, according to [4], a malicious user at least need to utilize the sum of all user gradients except themselves, i.e., $\boldsymbol{g}^{t+1} - \boldsymbol{g}_{self}^{t+1}$, in order to exploit membership inference attacks or attribute inference attacks to leak user privacy. In this paper, PS and AS assign a dynamic weight based on similarity to each user gradient through collaborative calculation, and this weight is unknown to the user. So malicious users will not be able to know the sum of other users' gradients because they are unaware of the weight of their own gradients.

Hence, the SFLBR holds the security property that malicious users cannot compromise other users' privacy. □

C. Proof of Lemma 3

Proof: When the learning rate is non-increasing and satisfies that $lr^t \le 2lr^{t+E}$, for any t, there always exists $t_0 \le t$ and $t - t_0 \le E - 1$. Therefore, $lr^t \le 2lr^{t_0}$, we have

$$\begin{aligned}
&\mathbb{E}\left(\sum_{i=1}^N \rho_i \|\overline{\boldsymbol{w}}^t - \boldsymbol{w}_i^t\|^2\right) \\
&= \mathbb{E}\left(\sum_{i=1}^N \rho_i \|(\boldsymbol{w}_i^t - \overline{\boldsymbol{w}}_0^t) - (\overline{\boldsymbol{w}}^t - \overline{\boldsymbol{w}}_0^t)\|^2\right) \\
&\le \sum_{i=1}^N \rho_i (lr^{t_0})^2 (E-1)^2 G^2 \\
&\le 4\sum_{i=1}^N \rho_i (lr^t)^2 (E-1)^2 G^2. \qquad (7)
\end{aligned}$$

We assume that the set of malicious users participating in FL is M, and the set of honest users is H. M and H satisfy $M \cup H = U$. In addition, since we have configured a maximum attacker ratio of 50% for different aggregation schemes, the global model will gradually converge to the optimal state when there is a smaller proportion of attackers in the system. At this point, the benchmark gradient we choose based on the median will gradually converge. The malicious gradient generated by malicious users will be given a smaller trust score due to direction misalignment. As the number of rounds increases, the malicious gradients' trust scores will decrease, while the honest gradients' trust score will increase, i.e., $\sum_{a=1}^{|M|} \rho_a \to 0, \sum_{b=1}^{|H|} \rho_b \to 1$.

Therefore, we have

$$\begin{aligned}
Eqn\ 7 &= 4(lr^t)^2 (E-1)^2 G^2 \left(\sum_{a=1}^{|M|} \rho_a + \sum_{b=1}^{|H|} \rho_b\right) \\
&= 4(lr^t)^2 (E-1)^2 G^2. \qquad \square \ (8)
\end{aligned}$$

Authorized licensed use limited to: Anhui University. Downloaded on October 10,2026 at 11:47:06 UTC from IEEE Xplore. Restrictions apply.

ACKNOWLEDGMENT

The authors are grateful to Na Wang (nawang@buaa.edu.cn) for assistance with English language editing.

REFERENCES

[1] B. McMahan, E. Moore, D. Ramage, S. Hampson, and B. A. Y. Arcas, "Communication-efficient learning of deep networks from decentralized data," in *Proc. Artif. Intell. Statist.*, 2017, pp. 1273–1282.

[2] G. N. Ahmad, H. Fatima, S. Ullah, A. S. Saidi, and Imdadullah, "Efficient medical diagnosis of human heart diseases using machine learning techniques with and without GridSearchCV," *IEEE Access*, vol. 10, pp. 80151–80173, 2022.

[3] L. Chen et al., "Milestones in autonomous driving and intelligent vehicles: Survey of surveys," *IEEE Trans. Intell. Vehicles*, vol. 8, no. 2, pp. 1046–1056, Feb. 2023.

[4] R. Shokri, M. Stronati, C. Song, and V. Shmatikov, "Membership inference attacks against machine learning models," in *Proc. IEEE Symp. Secur. Privacy (SP)*, May 2017, pp. 3–18.

[5] L. Zhu, Z. Liu, and S. Han, "Deep leakage from gradients," in *Proc. Adv. Neural Inf. Process. Syst.*, vol. 32, 2019, pp. 14774–14784.

[6] K. Bonawitz et al., "Practical secure aggregation for privacy-preserving machine learning," in *Proc. ACM SIGSAC Conf. Comput. Commun. Secur.*, Oct. 2017, pp. 1175–1191.

[7] G. Xu, H. Li, S. Liu, K. Yang, and X. Lin, "VerifyNet: Secure and verifiable federated learning," *IEEE Trans. Inf. Forensics Security*, vol. 15, pp. 911–926, 2020.

[8] K. Wei et al., "Federated learning with differential privacy: Algorithms and performance analysis," *IEEE Trans. Inf. Forensics Security*, vol. 15, pp. 3454–3469, 2020.

[9] X. Liu, H. Li, G. Xu, Z. Chen, X. Huang, and R. Lu, "Privacy-enhanced federated learning against poisoning adversaries," *IEEE Trans. Inf. Forensics Security*, vol. 16, pp. 4574–4588, 2021.

[10] Z. Ma, J. Ma, Y. Miao, Y. Li, and R. H. Deng, "ShieldFL: Mitigating model poisoning attacks in privacy-preserving federated learning," *IEEE Trans. Inf. Forensics Security*, vol. 17, pp. 1639–1654, 2022.

[11] A. Yazdinejad, A. Dehghantanha, H. Karimipour, G. Srivastava, and R. M. Parizi, "A robust privacy-preserving federated learning model against model poisoning attacks," *IEEE Trans. Inf. Forensics Security*, vol. 19, pp. 6693–6708, 2024.

[12] X. Gu, M. Li, and L. Xiong, "DP-BREM: Differentially-private and Byzantine-robust federated learning with client momentum," in *Proc. 34th USENIX Secur. Symp. (USENIX Secur. 25)*, 2025, pp. 3065–3082.

[13] M. Fang, X. Cao, J. Jia, and N. Gong, "Local model poisoning attacks to Byzantine-robust federated learning," in *Proc. 29th USENIX Secur. Symp.*, 2020, pp. 1605–1622.

[14] E. Bagdasaryan, A. Veit, Y. Hua, D. Estrin, and V. Shmatikov, "How to backdoor federated learning," in *Proc. Int. Conf. Artif. Intell. Statist.*, 2020, pp. 2938–2948.

[15] G. Baruch, M. Baruch, and Y. Goldberg, "A little is enough: Circumventing defenses for distributed learning," in *Proc. Adv. Neural Inf. Process. Syst.*, vol. 32, 2019, pp. 8635–8645.

[16] V. Shejwalkar and A. Houmansadr, "Manipulating the Byzantine: Optimizing model poisoning attacks and defenses for federated learning," in *Proc. Netw. Distrib. Syst. Secur. Symp.*, 2021, pp. 1–18.

[17] D. Yin, Y. Chen, R. Kannan, and P. Bartlett, "Byzantine-robust distributed learning: Towards optimal statistical rates," in *Proc. Int. Conf. Mach. Learn.*, Jul. 2018, pp. 5650–5659.

[18] P. Blanchard, E. M. El Mhamdi, R. Guerraoui, and J. Stainer, "Machine learning with adversaries: Byzantine tolerant gradient descent," in *Proc. Adv. Neural Inf. Process. Syst.*, vol. 30, 2017, pp. 118–128.

[19] X. Cao, M. Fang, J. Liu, and N. Z. Gong, "FLTrust: Byzantine-robust federated learning via trust bootstrapping," 2020, *arXiv:2012.13995*.

[20] Z. Zhang et al., "LSFL: A lightweight and secure federated learning scheme for edge computing," *IEEE Trans. Inf. Forensics Security*, vol. 18, pp. 365–379, 2023.

[21] Z. Tang, Y. Zhang, S. Shi, X. He, B. Han, and X. Chu, "Virtual homogeneity learning: Defending against data heterogeneity in federated learning," in *Proc. Int. Conf. Mach. Learn.*, 2022, pp. 21111–21132.

[22] L. Gao, H. Fu, L. Li, Y. Chen, M. Xu, and C.-Z. Xu, "FedDC: Federated learning with non-IID data via local drift decoupling and correction," in *Proc. IEEE/CVF Conf. Comput. Vis. Pattern Recognit. (CVPR)*, Jun. 2022, pp. 10102–10111.

[23] S. Shen, S. Tople, and P. Saxena, "Auror: Defending against poisoning attacks in collaborative deep learning systems," in *Proc. 32nd Annu. Conf. Comput. Secur. Appl.*, Dec. 2016, pp. 508–519.

[24] Y. Xie, M. Fang, and N. Z. Gong, "FedREDefense: Defending against model poisoning attacks for federated learning using model update reconstruction error," in *Proc. 41st Int. Conf. Mach. Learn.*, 2024, pp. 54460–54474.

[25] Y. Dong, X. Chen, K. Li, D. Wang, and S. Zeng, "FLOD: Oblivious defender for private Byzantine-robust federated learning with dishonest-majority," in *Proc. Eur. Symp. Res. Comput. Secur.*, 2021, pp. 497–518.

[26] P. Mai, R. Yan, and Y. Pang, "RFLPA: A robust federated learning framework against poisoning attacks with secure aggregation," in *Proc. Adv. Neural Inf. Process. Syst.*, 2024, pp. 104329–104356.

[27] F. Mo, H. Haddadi, K. Katevas, E. Marin, D. Perino, and N. Kourtellis, "PPFL: Privacy-preserving federated learning with trusted execution environments," in *Proc. 19th Annu. Int. Conf. Mobile Syst., Appl.*, Services, Jun. 2021, pp. 94–108.

[28] B. Woodworth et al., "Is local SGD better than minibatch SGD?" in *Proc. Int. Conf. Mach. Learn.*, 2020, pp. 10334–10343.

[29] E. Viola, "The complexity of constructing pseudorandom generators from hard functions," *Comput. Complex.*, vol. 13, nos. 3–4, pp. 147–188, 2005.

[30] T. Dierks and C. Allen. (1999). *The TLS Protocol Version 1.0*. [Online]. Available: https://api.semanticscholar.org/CorpusID:31760087

[31] X. Li, K. Huang, W. Yang, S. Wang, and Z. Zhang, "On the convergence of FedAvg on non-IID data," 2019, *arXiv:1907.02189*.

[32] K. He, X. Zhang, S. Ren, and J. Sun, "Deep residual learning for image recognition," in *Proc. IEEE Conf. Comput. Vis. Pattern Recognit. (CVPR)*, Jun. 2016, pp. 770–778.

[33] C. Fung, C. J. Yoon, and I. Beschastnikh, "The limitations of federated learning in Sybil settings," in *Proc. 23rd Int. Symp. Res. Attacks, Intrusions Defenses*, 2020, pp. 301–316.

Authorized licensed use limited to: Anhui University. Downloaded on October 10,2026 at 11:47:06 UTC from IEEE Xplore. Restrictions apply.